

OfficeBridge

클라이언트리스 제로트러스트 게이트웨이

STEP 2 · MVP 개발 결과 보고서

지란지교 해커톤 · [팀명을 입력하세요] · 2026-08-28

1. 개요

OfficeBridge는 VPN 클라이언트 설치 없이, 브라우저만으로 인가된 사내 시스템에 접속할 수 있게 하는 클라이언트리스 제로트러스트 게이트웨이입니다. 릴레이 서버가 사용자 인증·정책 판단·행위 기반 지속 검증을 담당하고, 고객 사내망에 설치된 커넥터가 아웃바운드 전용 연결로 실제 내부 시스템에 요청을 중계합니다.

이번 STEP 2에서는 PRD의 P0 범위(F-1~F-7)를 전부 동작하는 형태로 구현했고, 여기에 더해 실제 사내 ERP·GitLab을 연동해 mock 환경을 넘어선 end-to-end 시연이 가능한 상태까지 만들었습니다.

1.1 문제 정의

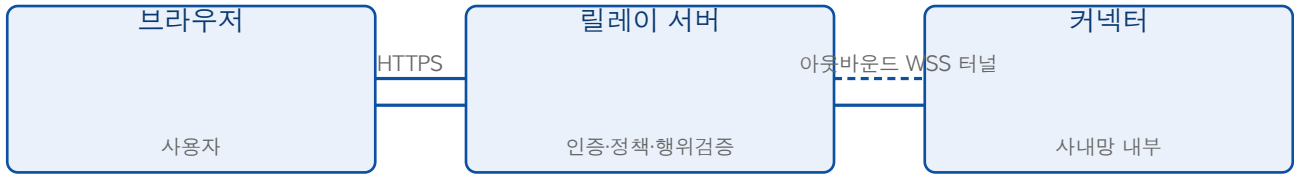
- 전통적 VPN은 접속 즉시 사내망 전체에 대한 네트워크 접근권을 부여해, 필요 이상의 노출 범위를 만든다.
- VPN 클라이언트 설치·설정은 재택/외근 인력, 협력사, 개인 기기 사용자에게 진입장벽이 된다.
- 로그인 이후에는 별도 검증 없이 세션이 유지되는 경우가 많아, 세션 탈취·이상행위에 취약하다.

1.2 해결 방향

- 브라우저 기반 접속 — 클라이언트 설치 없이 HTTPS로 접속.
- 화이트리스트형 접근 — 인가된 시스템 외에는 요청 자체가 사내망에 도달하지 않음.
- 지속적 검증 — 로그인 이후에도 업무시간·요청빈도·세션 IP 등을 계속 확인.
- 아웃바운드 전용 커넥터 — 벤더/릴레이가 고객 사내망에 인바운드 포트를 열 필요가 없음.

2. 아키텍처

브라우저는 릴레이 서버에만 접속하고, 릴레이는 고객 사내망에 인바운드로 접근하지 않습니다. 커넥터가 먼저 릴레이로 아웃바운드 WSS 터널을 맺고, 릴레이는 그 터널 위에 요청/응답을 실어 보냅니다.



핵심 보안 속성: 릴레이는 고객 사내망으로 인바운드 연결을 열지 않습니다. 커넥터가 항상 먼저 연결을 시작하고, 연결이 끊기면 3초 간격으로 자동 재연결합니다. 요청은 사용자 인증 → 행위 기반 지속 검증 → 정책 허용 여부 확인을 모두 통과해야 커넥터로 전달됩니다.

2.1 구성 요소

구성 요소	역할
릴레이 서버	사용자 인증, 부서/개인 정책 판단, 행위 기반 지속 검증, 감사로그, 관리자 콘솔, 임직원 포털
커넥터	아웃바운드 전용 터널 유지, 실제 내부 시스템 주소·on/off 상태 관리, 로컬 관리 웹 제공
mock-apps	데모용 가짜 내부 시스템 (ERP·GitLab·그룹웨어·회계) — 실제 배포 시 진짜 사내 시스템으로 대체

3. 핵심 기능 (P0)

ID	기능	설명
F-1	터널링	WS 위 JSON 봉투(request/response, id 매칭)로 릴레이↔커넥터 요청 중계
F-2	인증	이메일/비밀번호 로그인, 세션 쿠키, 로그인 5회 실패 시 계정 잠금
F-3	정책 엔진	부서 정책 U 개인 추가 권한. 미허용 시스템은 요청이 사내망에 도달하지 않음
F-4	행위 기반 지속 검증	업무시간외 차단·요청빈도 제한(10초 30회)·세션 IP 고정·세션 최대수명 8h
F-5	감사로그	로그인/접속/관리자조작 전체 기록, 관리자 콘솔에 SSE로 실시간 스트리밍
F-6	관리자 콘솔	대시보드·사내시스템현황·정책접근관리·행위기반제어·세션계정통제·로그조회
F-7	목업 앱	ERP·GitLab·그룹웨어·회계 4종, 127.0.0.1 전용 바인딩으로 외부 직접 접근 차단

3.1 P0 범위를 넘어 구현한 것

PRD의 P0 완료 후, 데모 신뢰도를 높이기 위해 아래 항목을 추가로 구현했습니다.

- 실제 사내 ERP(erp.jiran.com)·GitLab(git.jiransoft.co.kr) 연동 — mock이 아닌 실제 시스템으로 end-to-end 시연
- 커넥터의 HTTPS 백엔드 지원 — 원래 mock(HTTP)만 상정되어 있던 것을 실제 시스템 연동을 위해 확장
- 리다이렉트 도메인 재작성 — 실제 앱이 자기 도메인으로 리다이렉트할 때 게이트웨이 밖으로 새는 것을 방지
- 세션 쿠키 처리 개선 — 릴레이 자신의 세션 쿠키만 제거하고 실제 앱의 로그인 쿠키는 보존, Set-Cookie의 Domain 속성 제거로 브라우저 거부 문제 해결
- 커넥터 로컬 관리 웹(:8090) — 서비스 도메인 추가/삭제/on-off + 릴레이 정책·로그 읽기 전용 조회
- 사내시스템 현황 화면 실시간화 — 릴레이가 내부주소를 저장하지 않고, 커넥터가 보고하는 값을 그대로 표시
- Ant Design Pro 스타일 UI 리디자인 — 아이콘 사이드바, 브레드크럼, 아바타 드롭다운

4. 보안 설계

4.1 요청 판정 순서

모든 요청은 다음 순서로 판정됩니다. 어느 단계든 통과하지 못하면 커넥터·내부망까지 요청이 전달되지 않습니다.

- ① 내부 경로 (/_ob/*) 여부 확인 — 로그인/로그아웃/관리 API
- ② 세션 확인 — 미로그인 시 로그인 페이지로 리다이렉트
- ③ 행위 기반 지속 검증 — 업무시간/요청빈도/세션 IP/세션 수명
- ④ 정책 확인 — 부서/개인 권한
- ⑤ 커넥터로 전달 — 아웃바운드 터널을 통해 실제 내부 시스템에 중계

4.2 커넥터 소유권 원칙

내부 네트워크 지도(어떤 시스템이 어디 있는지)는 커넥터만 압니다. 릴레이는 서비스 이름과 정책만 다루고, 실제 내부주소·on/off 상태는 저장하지 않고 커넥터가 실시간으로 보고하는 값을 그대로 보여줍니다. 이는 벤더(릴레이 운영 주체)가 고객의 내부망 구조를 알 필요가 없도록 하는 설계입니다.

4.3 알려진 한계

한계	영향	대응 방향
세션·터널 상태가 인메모리	릴레이 재시작 시 전체 세션 소실	Redis 등 외부 세션 스토어 도입 (P1)
커넥터 토큰이 고정 공유값	토큰 유출 시 임의 장비가 커넥터로 위장 가능	커넥터별 고유 토큰 + mTLS/장비 바인딩
커넥터 서비스 삭제가 릴레이에 전파되지 않음	폐기된 시스템이 '연결 안됨' 상태로 남음	삭제 이벤트 브로드캐스트 추가
자체 서명 TLS 인증서	브라우저 경고 노출, 실사용 시 신뢰 문제	실배포 시 사설 CA 또는 공인 인증서로 교체

5. 검증 및 테스트

자동화된 유닛 테스트 스위트 대신, 실제 HTTPS 요청(curl)과 브라우저 조작으로 전체 플로우를 직접 재현하며 검증했습니다. 확인한 주요 시나리오는 다음과 같습니다.

- 미인증 접속 → 로그인 페이지 리다이렉트, TLS 핸드셰이크(TLSv1.3) 정상
- 로그인/로그아웃, 부서·개인 정책에 따른 허용(200)/차단(403) 분기
- 관리자 콘솔에서 정책 변경 시 재시작 없이 즉시 반영
- 짧은 시간 내 반복 요청 시 자동 차단(행위 기반 룰)
- 로그인 5회 실패 → 계정 잠금 → 관리자 잠금 해제 → 재로그인 가능
- 계정 차단 시 활성 세션 즉시 무효화
- 커넥터에서 새 서비스 추가 → 릴레이 사내시스템 현황 화면에 즉시 반영 (라이브 온보딩)
- 실제 ERP(erp.jiran.com) 로그인 화면 200 응답, 실제 GitLab(git.jiransoft.co.kr) 302 → /users/sign_in 리다이렉트가 게이트웨이 도메인으로 정확히 재작성되어 200 응답 — 실제 시스템 연동 확인
- mock 앱의 127.0.0.1 전용 바인딩으로 외부 직접 접근 불가 확인
- 감사로그(JSONL) 영속화 및 관리자 콘솔 실시간 스트리밍(SSE) 확인

6. 향후 계획 (로드맵)

항목	내용
F-8 추가 인증	OTP/생체인증 등 2차 인증 연동
F-9 AI 요약	감사로그 이상행위 자동 요약·알림
F-10 커넥터 모니터링	커넥터 상태·성능 모니터링 대시보드
F-11 개인 브릿지	개인 기기용 경량 접속 모드 (Agent Bridge)

단기적으로는 4.3절의 한계 대응(세션 영속화, 커넥터별 토큰, 서비스 삭제 전파)을 우선순위로 두고 있습니다.

7. 부록 — 접속 정보

화면	주소
임직원 포털	https://portal.10-52-249-21.sslip.io/
관리자 콘솔	https://admin.10-52-249-21.sslip.io/dashboard

이메일	부서	역할	접근 가능
kim.sales@demo.co.kr	영업팀	일반	ERP, 그룹웨어
lee.dev@demo.co.kr	개발팀	일반	GitLab, 그룹웨어
park.hr@demo.co.kr	인사팀	일반	ERP, 그룹웨어
admin@demo.co.kr	보안팀	관리자	전체 + 관리자 콘솔

비밀번호는 전부 demo1234 입니다.